

Section: CS

July 11, 2026

Multi-Party Authorization Proxy

Ian Barish

To see what has changed since the last report, view the diff [here](#).

Problem Statement

Background and statement of the theoretical or practical problem, issue or opportunity motivating the research.

A recurring weakness across modern systems is that high-consequence actions done on behalf of a group can be authorized by a single person acting alone. Software publishing is where this weakness hits hardest: a maintainer on a software team is able to publish a package to a public package registry such as PyPI or npm using their credentials and with no other approvals. Nothing requires a second person to agree that this exact artifact should ship, even if multiple developers have equal authority over the project. That single point of authority is the root of a recurring class of supply-chain compromises [1] that are front and center in cybersecurity news today. When one maintainer's account is compromised, whether it be through credential theft [2, 3], a poisoned CI pipeline [4], or a rogue contributor [5], the attacker inherits the unilateral power to push malicious code to every user, company, and dependent package downstream. Recent incidents have followed the same attack shape: one account, a single malicious push, with thousands of victims impacted [3, 6].

The problem is not simply solved by increasing layers of security on developer accounts. The defenses that registries have recently added, such as mandatory two-factor authentication [7] and Trusted Publishing [8], harden authentication, making it harder for an attacker to pretend to be a maintainer. None of them distribute the decision to publish itself. These two layers are orthogonal, authentication hardening does nothing if a threat actor can successfully gain the trust of maintainers, as the XZ Utils backdoor [9] showed. What is missing is authorization granularity, ensuring that several distinct people consent to specific code being shipped before it is sent downstream. The same gap extends beyond software publishing, no general-purpose web authorization solution requires multiple distinct people to cooperate before granting access to a protected resource.

Solution Statement

This research will (the overall aim of the research) in order to (how the research will address the problem) with specific work product/deliverables described.

Enterprise-grade cryptocurrency wallets have long used multi-signature (multi-sig) schemes [10], in which two or more parties must sign a transaction before it leaves a secure wallet. This ensures that the group of individuals that have a vested interest in the wallet authorize

anything that happens to it. My research adapts that principle to software publishing, introducing multi-party authorization. I will create a general-purpose multi-party authorization proxy that, for its headline use case, prevents any one individual from publishing a package to PyPI and instead requires a quorum of reviewers to approve a release before it is pushed downstream. The application is hosted as a web server, and when a developer attempts to publish a package to PyPI, the proxy will:

1. Intercept the request while saving it for publishing
2. Notify other maintainers that a package is attempting to be published
3. Gather enough approvals from the maintainers until a quorum is reached
4. Then forward the publish request on to the PyPI repository

The project will be a proof-of-concept, with the project's broader aim to demonstrate this gap concretely and advocate for multi-party authorization to become a platform-native capability of not only the package registries themselves, but of any system where one account should not hold unilateral power over a high-consequence action. The deliverable for the practicum is a complete, deployable proxy that enforces this quorum-based approval across the full publish lifecycle as a concrete proof-of-concept. The complete scope, user stories, and design decisions are specified in the MVP plan and Product Requirements Document.

Completed Tasks (Last 2 Weeks)

For this Progress Report, as I finalized my implementation and began to think about the project on a deeper level, I completed work on my project's evaluation. Working from a rough draft that I created a few weeks ago, I further developed the project's threat model to over 30 threats, aligned them to MITRE ATT&CK and STRIDE, categorized them into a "net-delta" axis and mitigation buckets, and developed tests, hardened the code, created an evaluation suite based off of the PRD user stories, and built a demo to show off the application. I also started to think about how the report is going to come together, creating a report outline to document my thoughts. This cycle's effort represents roughly 160 commits, 31 merged PRs, 25 issues closed, and 6,900 lines of application and test code and 5,800 lines of threat model and evaluation documentation.

- Developed the threat model into a robust, auditable, and categorized catalog. 30+ threats across groups, each categorized into a net-delta axis (Improved / Inherited / Introduced) and one of four mitigation buckets (executably demonstrated / by-design / operator-enforced / accepted limitation).
- Hardened the code against the identified threats, promoting some to the executably demonstrated bucket.
- Built threat-model tooling: a query/validate CLI and a marimo risk dashboard, with backing-test mapping surfaced from tests: frontmatter.
- Made a runnable evaluation suite using new and existing tests based off of the functionalities that must be included in the MVP.

- Built a three-act live demo to show off the application and for use in the final presentation, which stands up live applications similar to real-world developer environments.
- Drafted the final-report outline.

Tasks for the Next Project Report

What will you do over the next two weeks for your project?

1. Create and present the final presentation.
2. Begin writing the final report, starting with case studies, with the aim to have a rough draft by Progress Report 5.
3. Add finishing touches to project implementation.

Questions I Have or Issues I'm Running Into

Are there unanticipated obstacles, is something taking longer than you thought it might, or is there an area where the Instructional Team might be able to provide some direction or clarification?

This will be my first time writing a formal, white-paper-style report, so I want to make sure the framing is right before I start drafting. I've sketched a report outline and settled on a general-to-concrete structure: I introduce multi-party authorization as a general authorization primitive that more services should implement, but I evaluate it rigorously only for the concrete package-publishing use case, treating the broader applicability as motivation and future work rather than an evaluated claim. My main question is whether that is the right emphasis for a paper like this, or whether the instructional team would expect more a report that is weighted differently. Secondarily, does the outline look like it is missing any sections that a report of this kind should include, and are there common pitfalls I should watch for in my first paper of this type?

Methodology Paragraph Summary

Description of the methodology you are proposing to get from the starting point of your project to the final deliverable. Projects should employ some systematic process to get to your solution and a clearly identified way to evaluate it to ensure it solves the problem statement identified.

The project will follow an iterative and research-driven development process. I will start by conducting background research on multi-signature authentication cryptography primitives [11, 12, 13, 14, 15, 16, 17, 18], existing authentication systems [19], and any other relevant security design patterns. That research will then inform application specifications for the proxy and approval flow. I will then build a minimum viable product that implements the core flow of intercepting a request, collecting approvals until a quorum is reached, and forwarding the request to the target endpoint. After reviewing the MVP, I will identify any missing requirements, limitations, and security concerns, then return to do additional research and refinement of the specification before implementing the full system. I will then develop an evaluation system that ensures my project solves the problems it was set out to address. This evaluation system is detailed further in the Evaluation section below.

Timeline

Enter one task per row. Include only project tasks (not peer feedback or progress report submissions). Tasks must be actionable. Update the Status column each week (Completed / In Progress / Cancelled / etc.).

Week	Description of Task	Status
W1	Brainstorm ideas for the project	Complete
W1	Create Project Proposal	Complete
W2	Conduct broad project research	Complete
W2	Refine Problem/Solution Statement and Methodology	Complete
W2	Define Project Timeline	Complete
W2	Conduct research on multi-auth crypto primitives	Complete
W3	Develop authentication scheme	Complete
W3	Define high-level architecture and data flow	Complete
W4	Write detailed application specifications	Complete
W4	Create harness for AI assisted programming	Complete
W5	Decide on technology stack	Complete
W5	Develop minimum viable product	Complete
W6	Review MVP to identify missing requirements, limitations, and security concerns	Complete
W6	Develop MVP evaluation framework based on user stories, threat model, and comparisons to other solutions	Complete
W7	Develop robust threat model tied to an industry framework	Complete
W7	Build Evaluation suite based on threat model and user stories	Complete
W8	Build three-act demo to showcase the project	Complete
W8	Create report outline	Complete
W9	Create final presentation materials	Not Started
W9	Begin writing report	Not Started
W9	Write case studies	Not Started
W10	Write comparative evaluation arguments	Not Started
W10	Add finishing touches to project implementation	Not Started
W10	Continue writing report	Not Started
W11	Finalize report	Not Started

Evaluation

Include any evaluation plans and/or results by Progress Report 3. This may expand as you finalize the report.

The evaluation for my project rests on three claims, ordered by what a reader would want to know. First, the project solves a real problem. No existing control enforces multi-party human authorization of a registry publish bound to the exact artifact, a gap that I establish with a cited comparative matrix of existing controls, case studies on real incidents, and the industry's recent products that feature m-of-n approval, such as AWS's 2025 multi-party approval feature [20]. Second, that the proof-of-concept application works: the complete

package-publishing workflow runs end-to-end and holds at the adversarial boundary, shown by a runnable demo on the live stack with a backing integration test suite. Third, that it adds only a bounded set of new threats: rather than claim the proxy resists everything, I measure the net change against publishing without it, classifying every threat in my threat model as improved, inherited, or introduced, then sorting the threats the proxy owns into the four mitigation buckets below. The full method and evidence are in the project's evaluation plan.

Two potential evaluation axes are excluded with justifications. First, performance, as my solution relies on human reaction and approval times, which would trump any optimizations I could make to the program. Second, formal human-subject usability, as the system is a proof-of-concept meant to advocate for the functionality to be implemented in more industry solutions.

Summary of owned threats by evaluation bucket:

Bucket	Count	Threats
① Executably demonstrated	11	CORE-1, CORE-2, DOS-1, HOST-2, IDENT-1, IDENT-2, IDENT-5, PUB-1, PUB-2, VOTE-2, VOTE-3
② Argued by design	8	CODE-1, CORE-4, CRYPTO-1, HOST-3, IDENT-4, INFO-1, VOTE-1, VOTE-4
③ Operator-enforced	5	DOS-2, HOST-4, HOST-5, IDENT-6, VOTE-5
④ Accepted limitation	5	CODE-2, CORE-3, DOS-3, DOS-4, HOST-1

Net delta: 24 introduced · 5 improved · 4 unchanged (inherited).

Report Outline

Include an outline of your final report by Progress Report 4. This may expand as you finalize the report.

The final report targets the structure below to follow conventional paper headings, under each evaluated section a one-line *claim tag* names the evaluation-plan claim it carries, so the report and the evaluation plan stay linked. The full working outline lives at Practicum Work/Final Report/outline.md and may expand or change as I begin working on the report.

- Title & Abstract.**
- Introduction.** The project's motivation and contribution. States the thesis as a general-to-concrete bookend: multi-party approval is a *general* authorization primitive, which this paper instantiates and evaluates for package publishing as the strong, concrete use case. Includes a short *Solution in Brief* subheading describing what the proxy is.
- Background – Motivating Incidents.** Case studies on the incidents Shai-Hulud, 2025, and XZ Utils / CVE-2024-3094, 2024. What happened in the incident and why existing controls failed. Later sections will reference these incidents and describe how the project's added controls may have changed the outcome.
- Positioning & Gap Analysis.** *Carries Evaluation Claim 1 – “It solves a problem.”* Authorization layer vs. authentication layer, a comparative positioning matrix (controls

× attack scenarios), and how the proxy addresses each background case study. Doubles as the related-work engagement – the literature (2FA, Trusted Publishing, provenance/SLSA, CI gates, AWS m-of-n) is engaged as evidence for the gap rather than as a standalone survey.

5. **System Design.** *Carries Evaluation Claim 2 — “It works.”* Application architecture and the end-to-end request/approval flow, backed by the three-act demo and integration-suite evidence.
6. **Security Analysis.** *Carries Evaluation Claim 3 — “It adds only a bounded set of new threats.”* The net-delta model (Improved / Inherited / Introduced) and the four mitigation buckets over the threats the proxy owns.
7. **Discussion.** Limitations (colluding quorum, operator preconditions, proof-of-concept not hardened; excluded axes of performance and human-subjects usability) and Future Work & Generalizability, which closes the introduction’s generality bookend and is labeled explicitly unevaluated.
8. **Conclusion.**
9. **References.**
10. **Appendix.** Follows the progress-report appendix structure: AI Usage Disclosure, work-product pointers, the full threat-model classification table, and the capability checklist overflowing from System Design.

The principle for the page budget is depth goes into the contribution (gap analysis and the security net-delta), while the engineering of the POC (System Design) stays lean and figure-driven, with detail overflowing to the appendix. Three load-bearing visuals anchor the argument: a full-width comparative positioning matrix (Claim 1), an architecture and request/approval data-flow figure (Claim 2), and a net-delta classification table (Claim 3).

References

- [1] M. Ohm, H. Plate, A. Sykosch, and M. Meier, “Backstabber’s knife collection: A review of open source software supply chain attacks,” https://doi.org/10.1007/978-3-030-52683-2_2, 2020, DIMVA 2020. Accessed: 2026-06-25.
- [2] Python Software Foundation / PyPI Security, “Account takeover and malicious replacement of ctx project,” <https://python-security.readthedocs.io/pypi-vuln/index-2022-05-24-ctx-domain-takeover.html>, 2022, domain-takeover account compromise; disclosed 2022-05-24. Accessed: 2026-06-25.
- [3] Cybersecurity and Infrastructure Security Agency, “Widespread supply chain compromise impacting the npm ecosystem,” <https://www.cisa.gov/news-events/alerts/2025/09/23/widespread-supply-chain-compromise-impacting-npm-ecosystem>, 2025, shai-Hulud worm. Accessed: 2026-06-25.

- [4] —, “Emergency directive 21-01: Mitigate SolarWinds Orion code compromise,” <https://www.cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise-closed>, 2020, SUNBURST build-system compromise; issued 2020-12-13. Accessed: 2026-06-25.
- [5] event-stream contributors, ““i don’t know what to say.” (event-stream / flatmap-stream malicious dependency),” <https://github.com/dominictarr/event-stream/issues/116>, 2018, GitHub issue documenting the npm compromise. Accessed: 2026-06-25.
- [6] Palo Alto Networks Unit 42, ““shai-hulud” worm compromises npm ecosystem in supply chain attack,” <https://unit42.paloaltonetworks.com/npm-supply-chain-attack/>, 2025, accessed: 2026-06-25.
- [7] M. Borins, “Top-100 npm package maintainers now require 2FA, and additional security-focused improvements to npm,” <https://github.blog/security/supply-chain-security/top-100-npm-package-maintainers-require-2fa-additional-security/>, 2022, accessed: 2026-06-25.
- [8] Python Packaging Authority, “Publishing to PyPI with a trusted publisher,” <https://docs.pypi.org/trusted-publishers/>, 2023, accessed: 2026-06-25.
- [9] National Vulnerability Database, “CVE-2024-3094: Malicious code in xz / liblzma (5.6.0–5.6.1),” <https://nvd.nist.gov/vuln/detail/CVE-2024-3094>, 2024, cVSS 3.1 base score 10.0 (Critical). Accessed: 2026-06-25.
- [10] G. Andresen, “BIP 11: M-of-N standard transactions,” <https://github.com/bitcoin/bips/blob/master/bip-0011.mediawiki>, 2011, introduced M-of-N multisignature transactions to Bitcoin. Accessed: 2026-06-25.
- [11] A. Shamir, “How to share a secret,” <https://doi.org/10.1145/359168.359176>, 1979, commun. ACM 22(11):612–613. Accessed: 2026-06-25.
- [12] C. Komlo and I. Goldberg, “FROST: Flexible round-optimized Schnorr threshold signatures,” https://doi.org/10.1007/978-3-030-81652-0_2, 2020, SAC 2020; IACR ePrint 2020/852. Accessed: 2026-06-25.
- [13] J. Nick, T. Ruffing, and Y. Seurin, “MuSig2: Simple two-round Schnorr multisignatures,” https://doi.org/10.1007/978-3-030-84242-0_8, 2021, CRYPTO 2021; IACR ePrint 2020/1261. Accessed: 2026-06-25.
- [14] R. Gennaro and S. Goldfeder, “Fast multiparty threshold ECDSA with fast trustless setup,” <https://doi.org/10.1145/3243734.3243859>, 2018, ACM CCS 2018 (GG18). Accessed: 2026-06-25.
- [15] —, “One round threshold ECDSA with identifiable abort,” <https://eprint.iacr.org/2020/540>, 2020, IACR ePrint 2020/540 (GG20). Accessed: 2026-06-25.
- [16] J. Doerner, Y. Kondi, E. Lee, and A. Shelat, “Secure two-party threshold ECDSA from ECDSA assumptions,” <https://doi.org/10.1109/SP.2018.00036>, 2018, IEEE S&P 2018 (DKLS18). Accessed: 2026-06-25.

- [17] —, “Threshold ECDSA from ECDSA assumptions: The multiparty case,” <https://doi.org/10.1109/SP.2019.00024>, 2019, IEEE S&P 2019 (DKLS19). Accessed: 2026-06-25.
- [18] E. Boyle, R. Cohen, D. Data, and P. Hubaček, “Must the communication graph of MPC protocols be an expander?” <https://arxiv.org/abs/2305.11428>, 2018, CRYPTO 2018; J. Cryptology 36(3), 2023. Accessed: 2026-06-25.
- [19] Authelia, “Authelia: Free open-source IAM solution,” <https://www.authelia.com/>, forward-auth reverse-proxy reference architecture. Accessed: 2026-06-25.
- [20] Amazon Web Services, “AWS backup launches multi-party approval support for logically air-gapped vaults,” <https://aws.amazon.com/about-aws/whats-new/2025/06/aws-backup-multi-party-approval-logically-air-gapped-vaults/>, 2025, accessed: 2026-06-25.

Appendix

If there are notes, sources, or figures you want to reference, include them here. Draft work product should begin by Progress Report 3.

AI Usage Disclosure

For transparency, I wanted to include an AI Usage Disclosure in my progress reports encompassing how I've been using AI in my practicum. While artificial intelligence (LLMs) is used throughout this project, it is always under my direction and review. At the start of the project, AI helped me formalize my idea, research, and learn the foundational concepts that the project requires. My primary use of AI has been through iterative, adversarial dialog ("grilling") in which I stress-test my ideas or a design against the AI. I follow Matt Pocock's engineering skills for much of my software development process. Once ideas are settled, I use AI to plan the implementation, such as what vertical slices exist and how each should be built. It then writes the code using test-driven development and checks against the specifications we developed while grilling. I always review every AI-generated specification and implementation against my own understanding of what the project is and must be. The AI submits its programming work as pull requests, and no pull request is merged without my manual review.

For written reports, I use AI to help research, surface credible sources to cite, sharpen my ideas, and produce a rough draft. The meaning and thought behind the words are always my own, and I type every word in the body of these reports to ensure nothing is written without my full understanding, though I may borrow language and sentence structure from the AI-generated draft. I also often have AI review my writing against what we've been grilling on, the project specifications, or the code itself to ensure what I am writing is accurate and my understanding of the project is correct. I believe that my AI use for this project is rigorous; I learn a lot while using it, and it not only helps me be more efficient, but also improves my end product.

Draft Work Product

The draft work product for this project is the working MVP and the design corpus behind it, both in the project repository:

- The MVP implementation.
- The application specifications and Architecture Decision Records in the docs/ directory.
- The Product Requirements Document.
- The threat model.
- The evaluation plan that this report summarizes in the Evaluation section.

Full Threat-Model Classification

The table below is the full per-threat classification the Evaluation section summarizes: every threat the proxy *owns*, tagged with its net-delta axis and mitigation bucket. It lists only the 29 owned threats (24 introduced, 5 improved); the 4 inherited threats are unchanged by the proxy and omitted. *Residual* is the residual likelihood $\times$ severity, and *Tests* counts the backing tests mapped from each threat's tests: frontmatter. Buckets: ① executably demonstrated, ② argued by design, ③ operator-enforced, ④ accepted limitation. The full per-threat detail lives in docs/threat-model/.

ID	Title	Δ	Residual	Bkt	Tests
CODE-1	Application-Layer Vulnerability in the Proxy	introduced	low $\times$ critical	②	4
CODE-2	Supply Chain Attack on the Proxy Itself	introduced	low $\times$ critical	④	0
CORE-1	Single Approver Account Compromise	improved	high $\times$ high	①	8
CORE-2	API Token Theft	improved	high $\times$ medium	①	4
CORE-3	Insider Collusion	improved	low $\times$ critical	④	0
CORE-4	Authorization Repudiation	improved	low $\times$ low	②	1
CRYPTO-1	Cryptographic Implementation Failure	introduced	low $\times$ high	②	6
DOS-1	Request & Resource Flooding (Denial of Service)	introduced	high $\times$ low	①	5
DOS-2	Destructive Availability Attack	introduced	medium $\times$ low	③	0
DOS-3	Compromised Approver as Denial-of-Service (Deny Button)	introduced	medium $\times$ low	④	5
DOS-4	Approver Withholding (Liveness Attack)	introduced	medium $\times$ low	④	1
HOST-1	Proxy Host Compromise	introduced	low $\times$ critical	④	3
HOST-2	Database Write Compromise	introduced	medium $\times$ critical	①	9
HOST-3	Database Read Compromise	introduced	medium $\times$ high	②	5
HOST-4	Database Repudiation Attack	introduced	medium $\times$ medium	③	0
HOST-5	Configured Service-Credential Exposure at Rest	improved	low $\times$ critical	③	0
IDENT-1	Admin Account Compromise	introduced	medium $\times$ critical	①	5
IDENT-2	Enrollment Link Interception	introduced	medium $\times$ high	①	9
IDENT-4	Phishable Approver Authentication	introduced	high $\times$ high	②	0
IDENT-5	No Anti-Automation on Authentication Endpoints	introduced	high $\times$ high	①	5
IDENT-6	Declarative-Provisioning Rogue-Admin Injection	introduced	low $\times$ critical	③	0
INFO-1	Information Disclosure via Quorum Status & Approver Visibility	introduced	high $\times$ medium	②	4
PUB-1	Package Swap Between Upload and Publication (Payload Substitution)	introduced	low $\times$ critical	①	5
PUB-2	Proxy Bypass	introduced	medium $\times$ critical	①	4
VOTE-1	Proxy Session Hijacking (Login Session)	introduced	medium $\times$ high	②	5
VOTE-2	Captured-Credential Replay	introduced	low $\times$ high	①	6
VOTE-3	Browser-Borne Approval Coercion	introduced	low $\times$ high	①	2
VOTE-4	Approval-Request Fatigue	introduced	high $\times$ high	②	0
VOTE-5	Malicious Review Artifact on the Approver Endpoint	introduced	medium $\times$ high	③	2